THREAT INTELLIGENCE / SOC BRIEFING

BREEZE COMET

Cyber Threats Against Brazilian Financial Institutions

Attack Techniques • Threat Hunting • SOC Detection

10–15 minute presentation | English

Based primarily on Google Threat Intelligence Group / Mandiant reporting, 1 Sep 2026

What is BREEZE COMET?

A financially motivated intrusion cluster focused on the systems that move money.

WHO

Tracked by Google Threat Intelligence Group as BREEZE COMET; previously UNC5669.

TARGETS

Brazilian financial services, fintech, retail and e-commerce environments.

OBJECTIVE

Abuse trusted access and payment workflows to execute fraudulent transfers.

The key distinction

This is not only a customer-facing banking malware story. The reported operations target organizations and privileged systems that can initiate or process transactions.

SPEAKER CUE Introduce the actor, then emphasize that the attack surface includes payment infrastructure—not just bank customers.

Why Brazil’s payment ecosystem matters

The attacker’s goal is to abuse legitimate transaction authority.

PIX

Brazil’s instant-payment system. Fast settlement can compress the time available to detect and stop fraud.

STR

The Reserve Transfer System used for transfers between financial institutions.

BOLETO

A widely used Brazilian payment slip / invoice mechanism that can be part of payment workflows.

What the actor needs

- Persistent access to accounts in Active Directory or cloud environments
- Access to transaction-authorized applications, APIs and mutual-TLS (mTLS) credentials
- Knowledge of internal approval steps, integrations and anti-fraud controls

SPEAKER CUE Explain Pix, STR and boleto in plain English; stress that valid credentials can be abused for invalid transactions.

From initial access to fraudulent transfer

A simplified, defender-focused chain synthesized from reported activity.

1

GAIN ACCESS

Password spraying, voice phishing, compromised trusted websites, rogue devices or vulnerable services.

2

ESTABLISH FOOTHOLD

RMM tools, infostealers or backdoors; persistence and command-and-control.

3

DISCOVER & ESCALATE

Enumerate users, hosts, shares, cloud resources and credentials.

4

MOVE & TUNNEL

Abuse RDP/SMB and service accounts; route traffic toward protected financial systems.

5

ABUSE PAYMENT WORKFLOWS

Use privileged access and transaction pathways to initiate fraudulent transfers.

Reported impact pattern: multiple waves of fraudulent transactions were observed within 24–48 hours after privileged access was established.

SPEAKER CUE Walk left to right. Make clear this is a simplified model; real intrusions can skip, repeat or reorder stages.

Tools defenders should recognize

Tool names are clues—not standalone proof of compromise.

REALBREEZE

Custom LDAP brute-forcing / identity reconnaissance utility.

COBALTSPIN

Rust-based tunneler; reverse SOCKS5 proxy over WebSocket for routing into internal networks.

LIGHTPAINT

Java backdoor associated with VPN installation and persistence.

MILDFROST

Passive Java backdoor associated with covert DNS tunneling.

XWORM / RMM

Commodity backdoor and remote-management tools observed in access / persistence chains.

ADRecon / Impacket

Legitimate admin or testing utilities that can be abused for discovery and lateral movement.

SPEAKER CUE Avoid reading every detail. Pick COBALTSPIN and LIGHTPAINT as examples of why network and persistence telemetry matter.

What should the SOC look for?

Correlate endpoint, identity, network, cloud and payment telemetry.

IDENTITY

Password-spray patterns
New privileged logins
Service-account use from unusual hosts

ENDPOINT

Unexpected RMM installs
PowerShell discovery scripts
New startup shortcuts / services
Security logging or Defender changes

NETWORK

New outbound WebSocket / DNS patterns
SMB or RDP between unusual systems
Internal scanning / tunneling

PAYMENT & CLOUD

New API or certificate use
Secrets accessed by unusual workloads
Payee / amount / velocity anomalies
Transactions outside normal workflow

High-value alert idea

Privileged login + unusual host discovery + new tunnel / RMM + abnormal payment activity = investigate urgently.

SPEAKER CUE Explain why no single signal is enough. A correlation across separate data sources raises confidence.

A practical hunt: “Could this host reach payment systems?”

Use hypotheses, pivots and evidence—not only IOC matching.

HYPOTHESIS	A compromised workstation or service account is being used to discover and access payment infrastructure.
PIVOT 1 — IDENTITY	Review failed-login bursts, new admin grants, service-account logons and logins outside normal patterns.
PIVOT 2 — ENDPOINT	Inspect process trees, PowerShell logs, RMM installations, startup changes and security-control modifications.
PIVOT 3 — NETWORK	Map new RDP/SMB paths, internal scans, long-lived WebSocket sessions, unusual DNS and outbound connections.
PIVOT 4 — TRANSACTIONS	Correlate API / mTLS certificate use with new hosts, unusual callers, rapid transfer bursts and payee changes.

SPEAKER CUE Present this as a repeatable hunting workflow: start with a hypothesis and follow evidence across data sources.

When the signals line up: respond fast, preserve evidence

The first priority is to stop unauthorized transactions without destroying evidence.

1 VALIDATE	Confirm the alert; identify affected identities, hosts, services and transaction windows.
2 CONTAIN	Disable or restrict compromised accounts; isolate endpoints; block unauthorized remote access and tunnels.
3 PROTECT PAYMENTS	Use approved emergency controls to pause suspicious workflows / transactions; rotate or revoke exposed credentials and certificates.
4 INVESTIGATE	Preserve endpoint, identity, network, cloud and payment logs; build a timeline; identify persistence and scope.
5 RECOVER	Rebuild trusted systems, rotate secrets, restore controls and validate business workflows before returning to service.

Coordinate incident command, fraud operations, IT, legal/compliance and executive stakeholders.

SPEAKER CUE Stress coordination: a SOC-only response is not enough when payment operations may be affected.

Reduce the attacker's options

Prioritize controls around identity, privileged access and transaction integrity.

IDENTITY & ACCESS

Phishing-resistant MFA; tiered admin accounts; least privilege; monitor service accounts.

NETWORK & ENDPOINT

Segment payment networks; allowlist remote-management tools; EDR coverage; restrict admin protocols.

PAYMENT SECURITY

Protect mTLS keys and certificates; harden CI/CD secrets; dual control; independent transaction validation.

LOGGING & DETECTION

Centralize identity, endpoint, DNS, proxy, cloud, Kubernetes and payment audit logs; alert on log clearing and new tunnels.

EXERCISE & GOVERNANCE

Run tabletop exercises; test containment playbooks; establish fraud/SOC escalation paths; review third-party access.

SPEAKER CUE Tie mitigations back to the attack chain: every strong control removes a step or shortens attacker dwell time.

Three lessons for every SOC analyst

01 WATCH THE WORKFLOW

Legitimate tools and valid credentials can still be used for malicious purposes.

02 CORRELATE THE SIGNALS

Identity + endpoint + network + payment telemetry reveals more than isolated alerts.

03 DEFEND THE TRANSACTION

Payment authorization, certificates, secrets and approval controls are part of the attack surface.

Closing thought

The best detection is not simply “malware found.” It is recognizing when trusted access is being used in an untrusted way.

SPEAKER CUE Finish with the closing thought, then invite questions.

DISCUSSION

Questions?

Be ready to explain the difference between an IOC, a behavior and a detection hypothesis.

LIKELY QUESTION 1

Why is BREEZE COMET different from a typical banking trojan?

Suggested answer: reported activity focuses on compromising organizations and payment-processing access, not only stealing customer credentials.

LIKELY QUESTION 2

What would you correlate first in a SOC?

Suggested answer: privileged identity events, endpoint execution / persistence, unusual internal connectivity and payment anomalies.

Other likely questions: What is mTLS? Why monitor RDP/SMB? Why can validly signed transactions still be fraudulent?

SPEAKER CUE Use the prompts to rehearse short answers rather than memorizing every slide.

REFERENCES

Sources & further reading

Main factual source: Google Cloud / GTIG / Mandiant reporting published 1 September 2026.

01 **Google Cloud / GTIG — Financially Motivated Threat Actor BREEZE COMET Targets Brazil (1 Sep 2026)**

https://cloud.google.com/blog/topics/threat-intelligence/financially-motivated-threat-actor-breeze-comet-targets-brazil

02 **MITRE ATT&CK — Javali banking trojan (context on Brazil-focused banking malware)**

https://attack.mitre.org/software/S0528/

03 **MITRE ATT&CK — Chaes information stealer (context on financial information theft in Brazil)**

https://attack.mitre.org/software/S0631/

04 **CERT.br — Brazilian national incident response and cybersecurity coordination**

https://cert.br/

Note: The attack chain and hunt workflow in this deck are analyst-oriented summaries. Confirm technical details against the primary report before operational use.

SPEAKER CUE Mention that the primary source is the Google Threat Intelligence Group / Mandiant report; the other links provide context.